/\/ nebulock

AGENTIC THREAT HUNTING

HUNT WITH MEMORY. HUNT WITH AGENTS. · DEATHCON 2026

AGENTIC THREAT HUNTING FRAMEWORK — OPEN SOURCE, YOURS TO KEEP.

SYDNEY MARRONE

Nebulock. Threat hunter.
Author of **ATHF**, the framework you're running today.
Co-author of **PEAK**. **SANS** course author.
Founder of **THOR Collective**.

DEATHcon 2026

/\/ nebulock

BEFORE YOU PRESS PLAY — PAUSE POINT 0

```
python3 -m venv .venv && source .venv/bin/activate     # Windows: .venv\Scripts\activate
pip install 'agentic-threat-hunting-framework[all]'
cp providers/<your-provider>.env.example .env          # edit: paste your API key
python preflight/validate.py                           # all green = you're ready
```

- **Splunk:** the URL + login DEATHcon gave you · read-only · time picker **All time** · `index=thrunt`
- **MCP client:** point it at `athf-mcp` now, not in Module 4 — `providers/mcp.md`
- Everything: `github.com/Nebulock-Inc/agentic-hunting-workshop-deathcon-2026` · new to hunting? `PRE_READ.md`**, 10 min**

TIME RANGE: ALL TIME. EVERY SEARCH. EVERY TIME.

THE FIVE LEVELS OF AGENTIC HUNTING

LEVEL	NAME	WHAT IT MEANS	ATHF
L0	**AD-HOC**	Hunt in a search bar. Close laptop, hunt is gone.	—
L1	**DOCUMENTED**	Write the hunt down so it survives you.	`hunt new`
L2	**SEARCHABLE**	Find the next hunt by reusing the last.	`similar`
L3	**GENERATIVE**	Agent reads intel, hands you hypotheses.	`research new`
L4	**AGENTIC**	Agent has tools; finds what you haven't covered.	mcp

THE MEMORY IS THE MOAT.

LOCK — HOW A HUNT IS SHAPED

- **L — Learn:** what triggered this hunt? Intel, an anomaly, a gap.
- **O — Observe:** the hypothesis and the query. What behavior would this actor leave?
- **C — Check:** run it, triage it, rule things out. Dead ends count.
- **K — Keep:** the finding, the SPL, the verdict. `athf similar` reads this later.

> A ruled-out hypothesis is still a finding.

TEN COMMANDS. THAT'S THE WHOLE SESSION.

COMMAND	WHEN
`athf init`	ONCE, MODULE 1. ENTER THROUGH THE PROMPTS.
`athf hunt new …`	EVERY HUNT. OR COPY A TEMPLATE.
`athf hunt list` · `validate`	END OF EVERY LAB
`athf similar` · `hunt coverage`	MODULE 2 ONWARD
`athf research new`	MODULE 3
MCP: *"what should I hunt next?"*	MODULE 4 ONWARD

ALL OF IT IS IN `COMMANDS/`. RUN THE FILE; DON'T RETYPE IT.

A HUNT IS JUST A FILE

- `athf hunt new --title … --technique … --behavior …` scaffolds a Markdown record in `hunts/`.
- **Or skip the flags:** copy `templates/H-0004.md` into `hunts/`, fill in **Check** and **Keep** in your editor.
- Either way, `athf hunt validate` tells you if it's complete. `athf similar` reads it the same.
- The typing is not the lesson. **The writing-it-down is.**

THE SHAPE OF THE SESSION

#	MODULE	VIDEO	LAB
1	MANUAL + STRUCTURE	11 min	25 min
2	SEARCH + SIMILARITY	9 min	20 min
3	RESEARCH AGENTS	8 min	15 min
4	AGENTIC MCP	9 min	15 min
5	THE PIVOT — NO HAND-HOLDING	6 min	15 min

PAUSE SLIDE IN, DEBRIEF OUT, EVERY LAB. WATCH THE GAP OPEN.

/\/ nebulock

MANUAL HUNTING & STRUCTURE

FEEL THE PAIN OF AD-HOC HUNTING. EARN THE CURE.

MEET THE VICTIM: SUDO SHIPPING. FLEET LOGISTICS, DEVS MOVE FAST. THE SOC DOESN'T KNOW YET.

WHY WE START BY HAND

- **This is hunting, not triage.** No alert fired. Assume compromise, go looking with a hypothesis.
- **The intrusion:** Sudo Shipping — devs install build tooling from a public registry, no gate.
- A backdoored patch of a popular CLI ran at install time, with developer privileges.
- **The binary is signed. The hash is clean in every feed. There is no CVE.**
- You cannot hash your way out of this. The only way in is behavior.

THE BEHAVIORAL MINDSET

- **Pyramid of Pain:** hashes and IPs are trivial to change; TTPs are expensive.
- CRON GOBLIN gives you nothing at the bottom — clean hash, CDN-looking domain.
- **Hunt the shape, not the string:** trusted-dev-process → unexpected shell → recon.
- A `node` post-install spawning `cmd.exe`, then `whoami /all` + `net group "Domain Admins"` — that's not a build step.

ABLE — THE HYPOTHESIS IS A SENTENCE

Actor	CRON GOBLIN
Behavior	POST-INSTALL SCRIPT SPAWNS A SHELL
Location	DEVELOPER WORKSTATIONS
Evidence	`NODE` → `CMD.EXE` PARENT/CHILD IN EDR PROCESS EVENTS

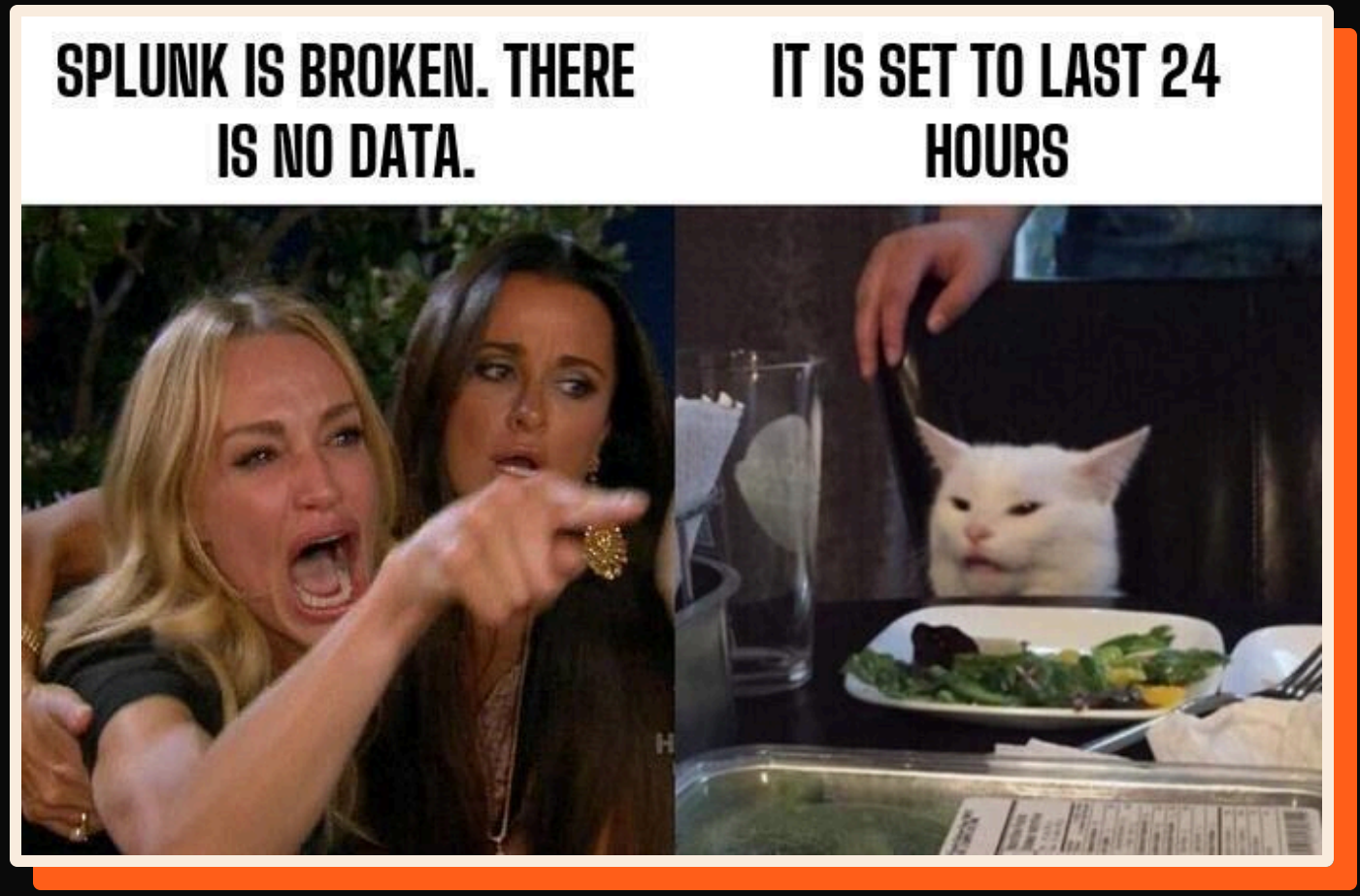
> "CRON GOBLIN uses a post-install script to spawn a shell on developer workstations; evidence is a `node` → `cmd.exe` parent/child in EDR." **If you can write it, you can hunt it.**

WRITE H-0004 DOWN — TWO WAYS, SAME FILE

```
# The flags way (it's in commands/m1-hunt-new-H0004.sh — run the file, don't retype it)
athf hunt new --title "Trojanized build-CLI post-install spawns shell + recon" \
  --technique T1195.002 --tactic execution --tactic initial-access \
  --actor "CRON GOBLIN" --behavior "post-install script spawns a shell that runs recon" \
  --hunter "<you>" --non-interactive

# The no-flags way
cp templates/H-0004.md hunts/   # metadata pre-filled; you fill Check + Keep
athf hunt validate
```

BOTH PRODUCE `HUNTS/H-0004.MD`. PICK THE ONE THAT GETS YOU BACK TO HUNTING FASTER.



SPLUNK ISN'T BROKEN. CHECK THE TIME PICKER.

LAB 1 — 25 MINUTES

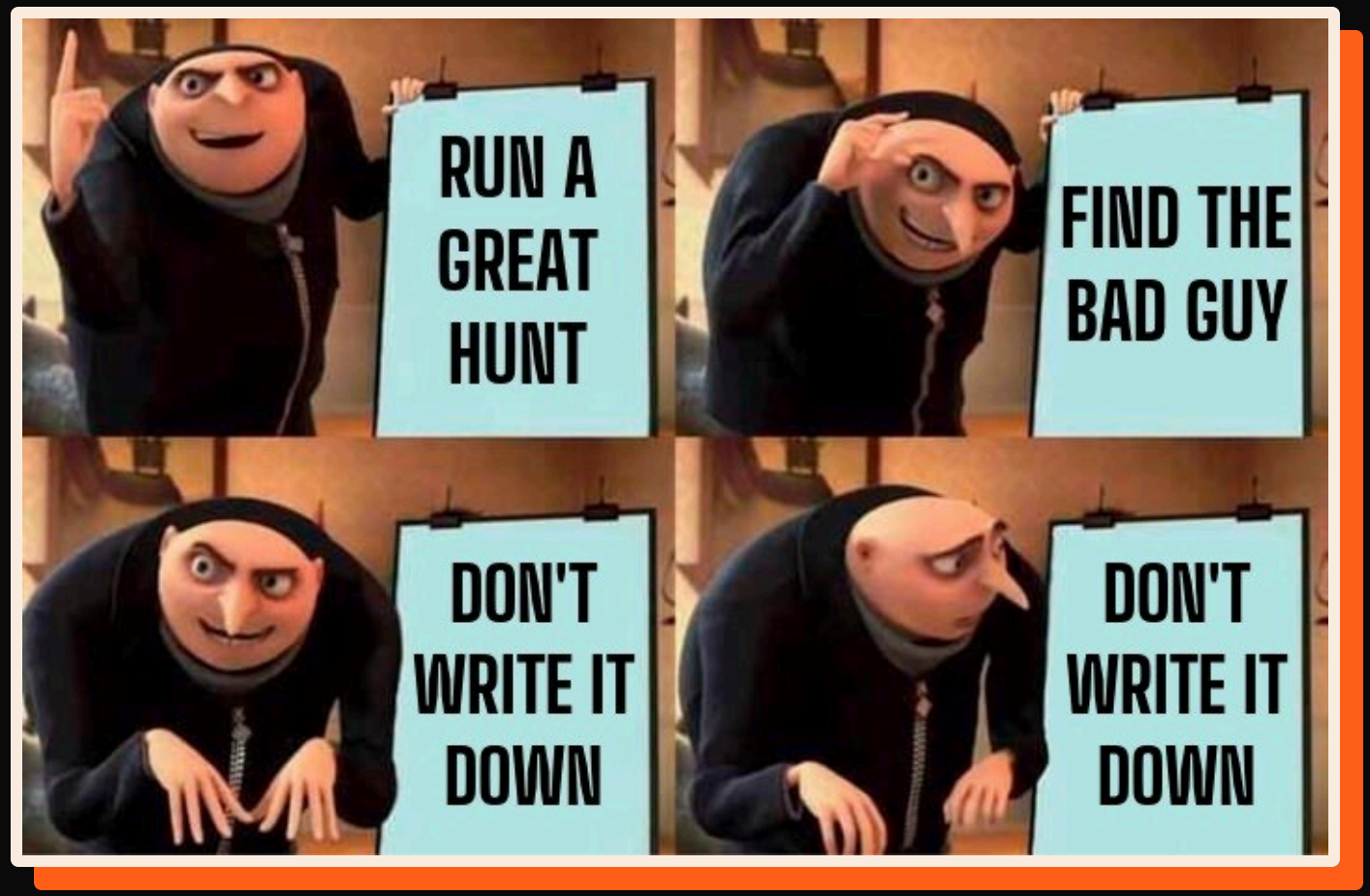
- Hunt Sudo Shipping by hand in Splunk. Workbook Module 1; queries in `queries/m1.md`.
- Write `H-0004` (post-install chain, *confirmed*) and `H-0005` (outbound after install, *needs-follow-up*) as you go — flags or template.
- "Done" = a re-runnable hypothesis, the exact SPL, a verdict, and what you ruled out.
- Time picker: `All time`.

PAUSE THE VIDEO HERE. COME BACK FOR THE DEBRIEF.

DEBRIEF — WHAT YOU SHOULD HAVE FOUND

```
index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
"node.exe" "cmd.exe"
properties.parent_image_path="*\\node.exe" properties.image_path="*\\cmd.exe"
| table _time hostname principal properties.parent_image_path properties.command_line
```

- **A1** `packmule-cli@2.4.1` install → `node postinstall.js` on `WS-BUILD-01`
- **A2** that `node.exe` spawns `cmd.exe` — an installer opening a shell
- **A3** the shell runs `whoami`, `net group`, `ipconfig` within ~2 min
- **H-0004** *confirmed*. **H-0005** (the beacon) *needs-follow-up* — on purpose.



THE HUNT YOU DON'T WRITE DOWN IS THE HUNT YOU RUN AGAIN.

/\/ nebulock

SEARCH & SIMILARITY

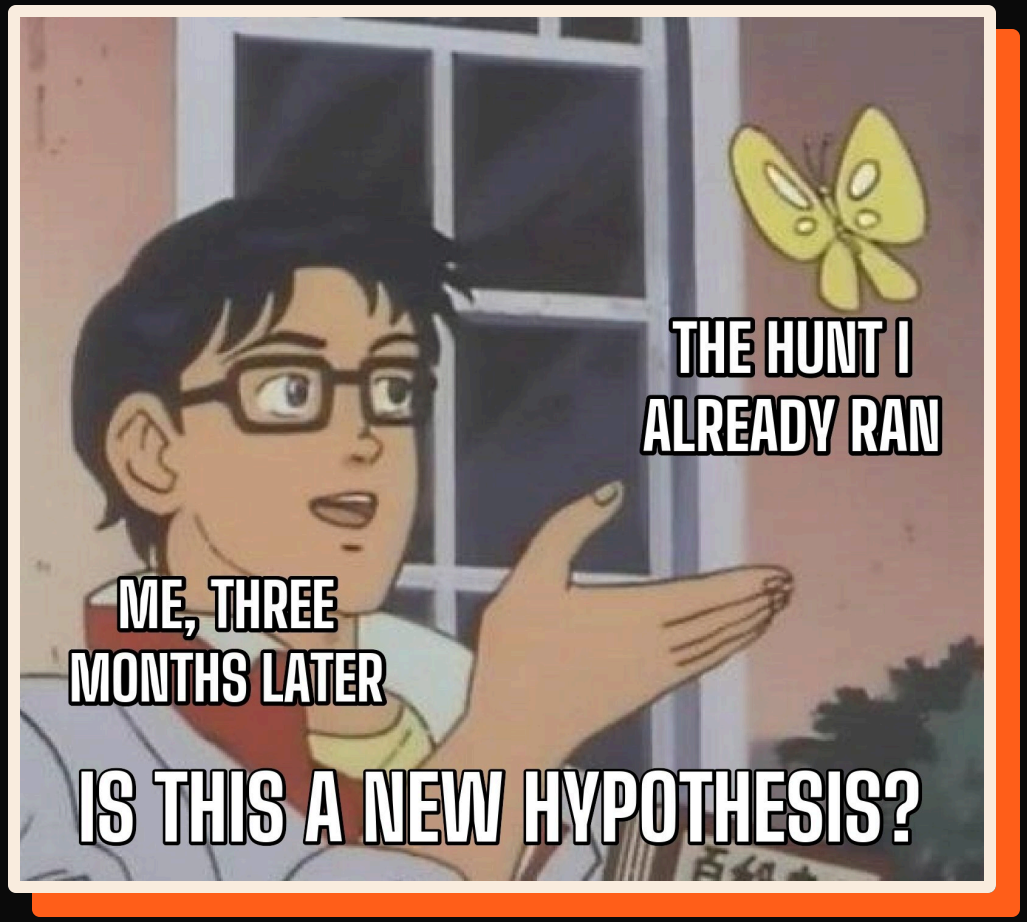
THE HUNT YOU WROTE DOWN STARTS PAYING RENT.

THE RIGHT COMMAND TURNS "NO" INTO "OKAY." SO DOES THE RIGHT CORPUS.

THE QUESTION MODULE 1 COULDN'T ANSWER

- You found WS-BUILD-01. **Was it the only victim?**
- Search the same host, same day, same command — and you miss the second one entirely.
- CRON GOBLIN time-shifted install two: over a day later, different developer's box, inside a legit build window.

> Keyword search only finds more of exactly what you already saw.



WITHOUT MEMORY, EVERY HUNT LOOKS LIKE A NEW ONE.

BEHAVIOR IS THE REUSABLE UNIT

- In H-0004 you wrote a shape: **trusted-dev-process → unexpected shell → recon child.**
- That sentence is host-agnostic, time-agnostic, user-agnostic.
- Indicators rot — the IP, the domain, the hostname all change on the next box.
- Pivot the *shape* across all hosts and all time, and the second victim falls out.

TWO COMMANDS DO THE L2 WORK

COMMAND	QUESTION IT ANSWERS
`athf similar --hunt H-0004`	"WHAT HAVE I HUNTED LIKE THIS BEFORE?"
`athf similar "post-install shell recon"`	FREE-TEXT AGAINST YOUR CORPUS
`athf hunt coverage`	"WHAT HAVE I *NOT* HUNTED?"
`athf hunt coverage --detailed`	TECHNIQUE-TO-HUNT MAPPING

LAB 2 — 20 MINUTES

- Orient: `athf similar` / `coverage` off your Module 1 hunts. Queries in `queries/m2.md`.
- Pivot the H-0004 shape across every host and all time. Find the **`second-wave victim`** (A4).
- Write **`H-0006`** (`templates/H-0006.md` if you'd rather not type flags) and name what found it.
- Time picker: **`All time`**.

PAUSE THE VIDEO HERE. COME BACK FOR THE DEBRIEF.

DEBRIEF — THE HIDDEN VICTIM

```
index=thrunt sourcetype="evidenceforge:ecar:json" object=PROCESS action=CREATE
"cmd.exe" ("whoami.exe" OR "systeminfo.exe" OR "net.exe" OR "ipconfig.exe")
properties.parent_image_path="*\\cmd.exe"
properties.image_path IN ("*\\whoami.exe","*\\systeminfo.exe","*\\net.exe","*\\ipconfig.exe")
| stats min(_time) as first values(properties.image_path) as cmds by hostname principal
```

- Indicator search (`WS-BUILD-01`, `packmule-cli`): **one host**, even on All time.
- The shape, host-agnostic: `WS-DEV-04` **/ carol.grep**, ~25 h later. That's **A4**.
- `sharp@0.33.2` → `node-gyp rebuild` looks similar and is **benign**: it compiles, no recon.
- **H-0006** note: *"keyword search failed; the behavioral pivot off H-0004 found this."*

/\/ nebulock

AI RESEARCH AGENTS

THE AGENT GENERATES THE HYPOTHESIS. SPLUNK CONFIRMS IT.

RESEARCH IS THE STEP BEFORE THE HUNT

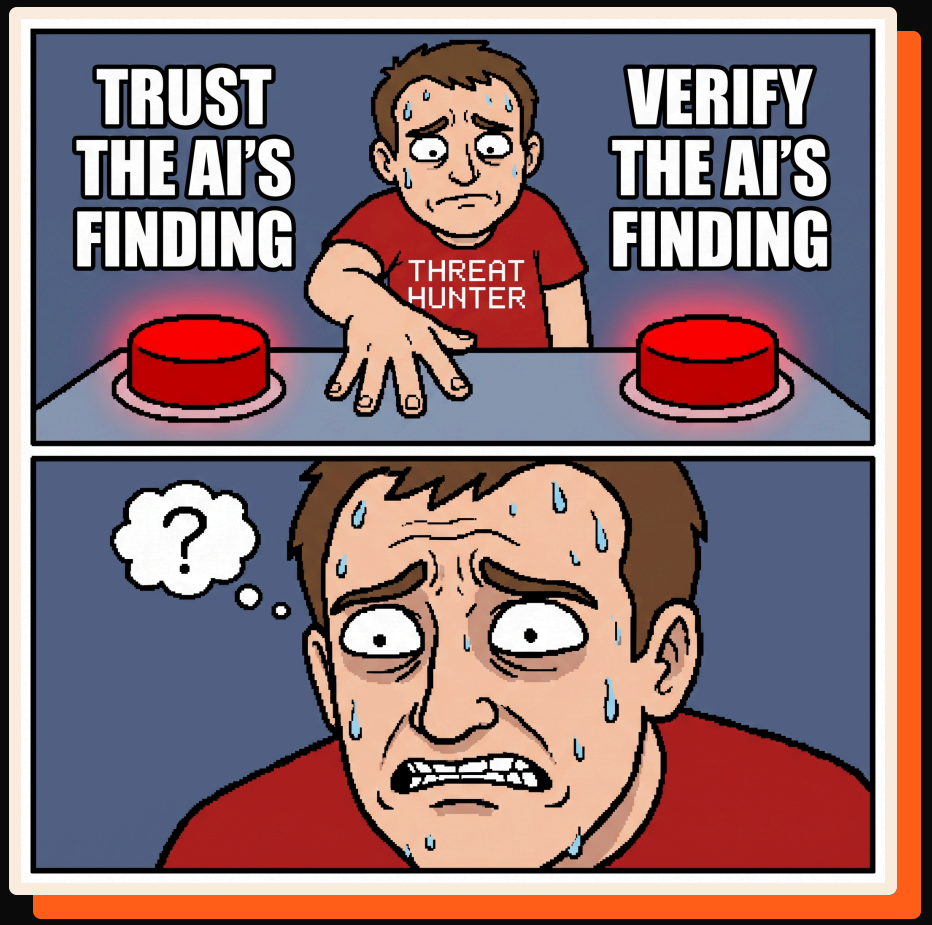
- Everything so far was **hunting**: you had a hypothesis, you tested it.
- **Research** is the step *before* the hypothesis — read intel, understand tradecraft, generate directions.
- Two objects in ATHF: a **research doc** (`athf research new`) proposes; a **hunt** (`athf hunt new`) tests.
- Research feeds hunts. Link them: `athf hunt new --research R-0001`.

WHERE YOU'RE STUCK WITHOUT RESEARCH

- Module 1 left an open thread: H-0005's beacon to `cdn-packmule-telemetry.net`.
- You **observed** it. You couldn't **characterize** it.
- Is 5-minute periodicity meaningful? How would you link this domain to *other* actor infra? Is there a low-and-slow second channel?
- **That's a knowledge gap, not a data gap.** The events are right there.

L3 IS THE FIRST PLACE THE AI CAN BE CONFIDENTLY WRONG

- **Research generates hypotheses; it does not confirm them.** Confirmation lives in Splunk, not the doc.
- **It assumes fields you don't have.** The agent says pivot on JA3 — your Zeek `ssl` has no `ja3` column. Adapt the *idea* to the field you have: the shared hosting block `203.0.113.44/30`.
- **It costs tokens and time.** `--depth basic --no-web-search` in the lab. Research deliberately, not reflexively.



THERE'S ONLY ONE BUTTON. VERIFY. ALWAYS VERIFY.

LAB 3 — 15 MINUTES

```
athf research new --topic "HTTPS C2 beacon detection via TLS JA3 pivoting and shared infrastructure; git-hook persistence in developer environments" \
  --technique T1071.001 --depth basic --no-web-search      # commands/m3-research-new.sh — start it FIRST
```

- While it runs: hunt the git-hook persistence (A5). Then read the doc — every concrete claim is a lead, not a fact.
- Pivot on what it tells you. Confirm in Splunk. Write `H-0007` with `--research R-XXXX`.
- Time picker: `All time`.

PAUSE THE VIDEO HERE. COME BACK FOR THE DEBRIEF.

DEBRIEF — THE SECOND CHANNEL

```
index=thrunt sourcetype="bro:ssl:json" id.resp_h="203.0.113.44/30"
| stats count values(id.resp_h) as ips by server_name
```

- Research said *pivot on JA3*. `ssl.log` has no `ja3`. **The idea survives; the field changes.**
- Same /30, second domain: `assets-packmule-cdn.com` (.45), six callbacks over days. **A8**.
- Decoy `static.docs-cdn.io` sits at .60, outside the /30. Ruled out.
- **A5** `core.hooksPath` → `pre-commit.cmd` → `node loader.js --beacon`. Same shape, aimed at git.

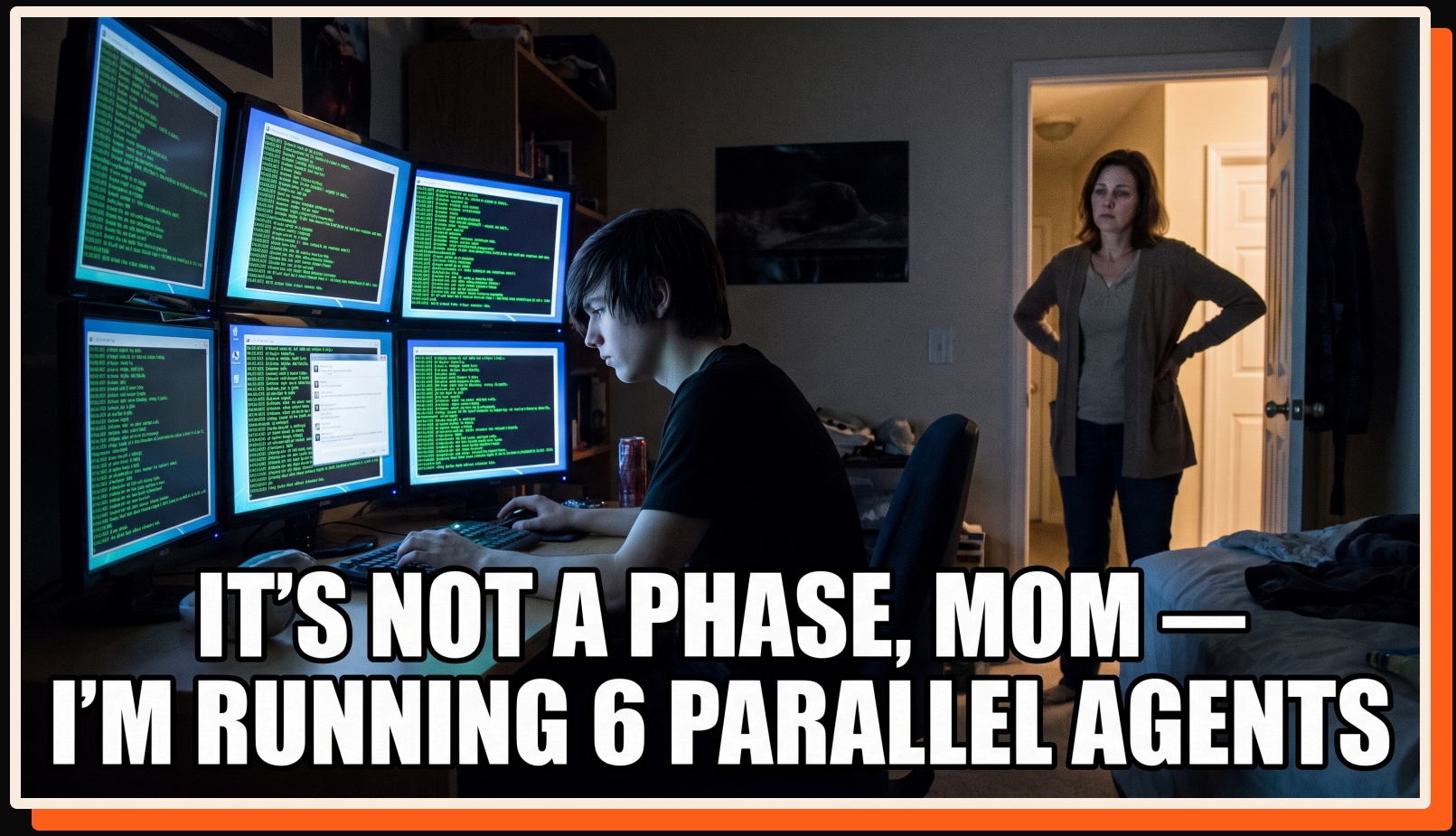
/\/ nebulock

FULL AGENTIC HUNTING VIA MCP

THE AGENT READS YOUR REPO AND NAMES WHAT YOU MISSED.

WHAT CHANGES AT L4

- **L3:** the agent read *the world* — threat intel — and gave you hypotheses.
- **L4:** the agent reads *your work* — your corpus, your coverage — and names *your* blind spots.
- L3 explains DNS tunneling in general. L4 says: **"you have C2 and cred-access covered, nothing on exfil — here's the query."**
- It knows what *you* haven't done because it can see your repo.



AT L4 THIS ISN'T A BIT. PARALLEL AGENTS, ALL READING YOUR REPO.

MCP IN ONE SLIDE — AND THE FIVE TOOLS

TOOL	WHAT IT DOES
`generate_hunt_hypothesis`	PROPOSE A HYPOTHESIS FROM INTEL
`search_hunts_by_text`	FULL-TEXT SEARCH ACROSS YOUR CORPUS
`find_similar_hunts`	THE MCP FORM OF `ATHF SIMILAR`
`list_coverage_gaps`	**THE STAR:** WHICH PHASES HAVE NO HUNT YET
`propose_next_query`	TURN THE BIGGEST GAP INTO A CONCRETE QUERY

MCP HANDS THE AGENT CALLABLE TOOLS. THESE FIVE READ YOUR REPO, NOT A SUMMARY OF IT.

WHY COVERAGE-GAP DETECTION IS THE WHOLE POINT

- Modules 1–3 found what you *went looking for*.
- The two hardest artifacts — cred-access (A9) and DNS-tunnel exfil (A10) — share one property: **you don't know you haven't found them.**
- No open thread points at them. At L0–L2 you simply *stop*.
- `list_coverage_gaps` reads your hunts, maps kill-chain phases, reports: **cred-access ✕, exfil ✕.**

YOU DRIVE IT IN PLAIN ENGLISH

- You will **not** type `list_coverage_gaps`.
- You ask what you'd ask a senior hunting partner: **"What have I hunted?"** / **"What should I hunt next?"**
- The agent picks the tool. Your corpus becomes something you *talk to*.
- Tool names stay as a fallback — offline, or when a question misfires.

LAB 4 — 15 MINUTES

- Ask your repo what you've hunted. Then ask what to hunt next.
- Chase the two Tier-3 gaps it names — cred-access and DNS-tunnel exfil. Queries in `queries/m4.md`.
- Produce `H-0008`. Handshake broken? CLI fallbacks are in the workbook — don't burn the module on config.
- Time picker: `All time`.

PAUSE THE VIDEO HERE. COME BACK FOR THE DEBRIEF.

DEBRIEF — THE GAPS NOBODY POINTED AT

```
index=thrunt sourcetype="bro:dns:json" qtype_name=TXT
"exfil-packmule.net" query="*.exfil-packmule.net"
| eval label=mvindex(split(query,"."),0) | eval len=len(label)
| stats count avg(len) as avg_label_len by id.orig_h
```

- `list_coverage_gaps` over four hunts → **cred-access ✕, exfil ✕.** Your repo pointed there; your data didn't.
- **A9** the beacon reads `.env`, `.aws\credentials`, `.netrc` — theft hiding in normal file reads.
- **A10** long, high-entropy TXT subdomains to `exfil-packmule.net` — exfil hiding in DNS noise.
- **H-0008** `--threat-context`: *"found via list_coverage_gaps."*

/\/ nebulock

SAME ACTOR, NEW TTP

SAME ACTOR. NEW BATTLEFIELD. 15 MINUTES. GO.

CRON GOBLIN. THE ACTOR YOU'VE HUNTED ALL SESSION JUST CHANGED THE GAME.

THE PIVOT

> "New intel on CRON GOBLIN — the same actor behind the trojanized `packmule-cli` — shows they've pivoted. No more waiting for developers to install a bad package. They've compromised a maintainer's access to a trusted internal repo and are injecting malicious build steps straight into your CI/CD pipeline. The runner does the work now. Same actor. Same infrastructure. New technique. The new campaign is already in your Splunk. You have 15 minutes. Go."

WHY THE PREPARED HUNTER WINS

- **Documented Campaign 1:** a repo full of hunts on C2, cred-access, exfil — the exact behaviors CRON GOBLIN reuses.
- `athf similar` + MCP links the new artifacts to old hunts in seconds. **"Same actor, new host"** falls out for free.
- **Worked ad-hoc (L0):** you'd have nothing to reuse. A blank search bar against unfamiliar CI telemetry.

> Watch the gap between those two hunters. That gap is the product.

THE UN-HUNTED ATTACKER'S WHOLE ADVANTAGE IS TIME YOU DIDN'T SPEND LOOKING.

▮▮ LAB 5 — 15 MINUTES. THE CLOCK STARTS WHEN YOU PAUSE.

- Fast route: the `curl | sh` build step nobody committed → ask your repo *"does this share infra with anything I've hunted?"* → **`H-0009`**.
- Cite the earlier hunt it reused. That citation is the whole story in one line.
- Ask your repo before you open the answer key.
- Time picker: **`All time`**.

PAUSE THE VIDEO HERE. DON'T SCRUB AHEAD — THE NEXT SLIDE IS THE ANSWER.

DEBRIEF — SAME ACTOR, PROVEN

```
index=thrunt sourcetype="apache:access:json" server="cdn-packmule-telemetry.net"
| stats count values(user) as users by client
```

- **M5-A1** `CI-RUNNER-03` runs `curl -fsSL … | sh` — a build step nobody committed.
- **M5-A3** ★ one proxy query: a Campaign-1 workstation **and** the runner, **same C2 domain**. Same actor.
- Stretch **M5-A2** IMDS cred theft (your H-0008 shape). **M5-A4** `curl -T` to an attacker bucket; `sudo-releases` is the legit deploy.

/\/ nebulock

WHAT YOU BUILT, AND WHAT'S NEXT

SIXTY MINUTES OF VIDEO, NINETY OF HUNTING. SIX HUNTS. ALL YOURS.

THE ARC YOU JUST WALKED

LEVEL	WHAT YOU DID	TOOL
L0	HUNTED IN A SEARCH BAR.	—
L1	WROTE THE HUNT DOWN.	`athf hunt new`
L2	BEHAVIOR FOUND A HIDDEN VICTIM.	`athf similar`
L3	AN AGENT NAMED WHAT TO HUNT.	`athf research new`
L4	AN AGENT NAMED YOUR BLIND SPOT.	MCP

EACH LEVEL ONLY WORKED BECAUSE THE ONE BELOW IT WROTE SOMETHING DOWN.

THE MOMENT THAT MATTERED

- **Module 5**: Same actor, new battlefield, 15 minutes.
- Documented hunters linked the CI beacon to Campaign-1 infra in seconds — *"same actor, new host."*
- The ad-hoc hunters started **cold**.

THAT GAP IS THE WHOLE THESIS: MEMORY IS THE EDGE. NOT A BIGGER MODEL. THE FACT THAT YOU WROTE IT DOWN.

BEHAVIOR OVER INDICATORS

- The binary was signed. The hash was clean. There was no CVE.
- Every artifact you found today was **behavioral** → a shape that transfers across hosts, time, and infrastructure.
- Indicators rot. Behavior persists. It is the durable signal.

THAT'S NOT A SLOGAN. YOU JUST SPENT NINETY MINUTES PROVING IT.

BURY THE INDICATOR. KEEP THE BEHAVIOR.

"WHAT HAPPENS AT 500 HUNTS?"

- Someone asks this every time. Good question. Short answer: **the agent never reads the whole corpus.**
- `athf similar` **ranks**, it doesn't read — the corpus is vectorized, the agent sees the top matches.
- `list_coverage_gaps` is an **aggregate** over hunt metadata, not a pass over every record.
- Token caps are per call. A big corpus makes the ranking *better*, not the context bigger.
- And hunts are files in a repo. Git scales. Prune, tag, archive like any other codebase.

IT'S ALL YOURS

- **ATHF is open source, on PyPI.** Vendor-neutral by design.
- Anthropic, OpenAI, Bedrock, Ollama — whichever key you brought, it ran. Vendor-neutral by design.
- Nothing you learned is locked behind a login.

TAKE THE REPO. TAKE THE WORKFLOW. RUN IT AGAINST YOUR OWN TELEMETRY MONDAY.

TAKE THE REPO. TAKE THE WORKFLOW. RELISH THE HUNT.

THE SIBLING QUESTION

- You hunted these behaviors *once*.
- The obvious next question: how do you catch them *every* time, automatically, with no human in the loop?
- **Hunting finds the unknown. Detection operationalizes the known.**

THAT HAND-OFF — HUNT → DURABLE DETECTION — IS WHERE MOST TEAMS LOSE THEIR WORK.

ADEF — THE SIBLING FRAMEWORK

- **ADEF — the Agentic Detection Engineering Framework.** ATHF's sibling.
- ATHF asks *"what happened that we didn't know about?"*
- ADEF asks *"how do our findings become detections that never miss it again?"*
- Same philosophy — behavior-first, memory-first, AI-augmented, open — pointed at the detection lifecycle.

TAKE THESE WITH YOU

- `ATHF` — `pip install agentic-threat-hunting-framework` · github.com/Nebulock-Inc
- `ADEF` — the sibling, same org: your hunts become durable detections
- `Workshop materials` — github.com/Nebulock-Inc/agentic-hunting-workshop-deathcon-2026
- `Live Q&A at DEATHcon` — ask in the workshop Discord channel. Bring your H-0009 and what stumped you.
- `The survey` — 90 seconds. It shaped this version.

THANK YOU FOR HUNTING WITH US.

/\/ nebulock

ONE LAST THING

Poked at the weird stuff?
The hot-dog service account, the Pokémon on the dev VLAN, the `hunter2` in a `.env`? This one's for you.

THE GLIZZARD SALUTES THE CURIOUS. STAY CURIOUS. HUNT WEIRD.